PONTO 1 · SDLC SEGURO

SDLC seguro quando a IA escreve o código

O ciclo vira um loop. O controle sai do hábito e entra no sistema.

O PROBLEMA

Código deixou de ser o gargalo

- O gargalo migra para planejar, revisar e implantar
- Controles feitos para código humano deixam de bater com a realidade
- Exceção esperando comitê vira custo de governança

A MUDANÇA

De linha reta para loop

Julgamento humano fica acima do loop

1 **Plan** → 2 **Design** → 3 **Build** → 4 **Test** → 5 **Deploy** → 6 **Maintain**

↺ achado em produção volta como nova intenção

PONTE COM O PONTO 1

As cinco fases da Janca cabem nos seis estágios

JANCA (2020)	LOOP COM IA (2026)
Requisitos	Plan
Design	Design
Código	Build
Testes	Test
Deploy e manutenção	Deploy + Maintain

RASTREABILIDADE

Cada estágio commita o que o próximo lê

`intent.md` → `spec.md` → `plan.md` → `diff + testes` →

`PR revisado` → `incidente`

Artefatos versionados + histórico de commits = trilha de auditoria

ESTÁGIO 1 · PLAN

Intenção antes de requisito

ARTEFATO

`intent.md`: problema, quem é afetado, restrições

SEGURANÇA

Dado sensível e restrição entram já na intenção

ESTÁGIO 2 · DESIGN

A política revisa a spec

ARTEFATO

`spec.md` **gerada a partir da intenção**

SEGURANÇA

Skill de segurança sinaliza conflito; o dono da política decide

ESTÁGIO 3 · BUILD

Plano primeiro, código depois

ARTEFATO

`plan.md` feito em modo leitura, sem editar nada

SEGURANÇA

Hook bloqueia caminho protegido e segredo no diff

ESTÁGIO 4 · TEST

O agente precisa provar o próprio trabalho

ARTEFATO

Teste que falha primeiro, protegido contra edição

SEGURANÇA

Todo incidente vira caso de eval permanente no CI

ESTÁGIO 5 · DEPLOY

Quem escreveu não aprova

ARTEFATO

PR revisado contra `REVIEW.md`: bug, segurança, aderência à spec

SEGURANÇA

Agente vai até o portão de produção; quem passa é uma pessoa nomeada

ESTÁGIO 6 · MAINTAIN

Detecção determinística aciona o agente

1σ
registra

2σ
diagnostica, só leitura

3σ
propõe PR ou runbook aprovado

O achado vira um novo `intent.md`, e o loop fecha.

CONTROLE

Aconselhar não é impedir

TIPO	MECANISMO	EFEITO
Advisory	Skill	Torna a conformidade **provável**
Enforced	Hook, permissão, branch protection	Torna a violação **quase impossível**

Regra que sempre tem que valer precisa de trava determinística.

GUARDRAILS GERENCIADOS

O que o engenheiro não desliga

- Leitura de `.env`, segredos e credenciais negada
- `curl`, `wget` e rede não aprovada bloqueados
- Sandbox com allowlist de domínio que falha fechado
- Sem modo bypass; só hooks e MCP gerenciados
- CI com token curto e escopado, sem credencial fixa de produção

PRINCÍPIOS

Quatro regras que não quebram

Separação de funções

Agente não tem rota direta para a main

Controle no sistema

Não no hábito nem na documentação

Portão humano

Produção exige autorização nomeada

Tudo é evidência

Commit, plano, review, decisão de hook

O loop continua rodando.
O julgamento humano fica acima dele.

Claxton, L. (2026). *The AI-native SDLC playbook*. Anthropic.

Janca, T. (2020). *Alice and Bob Learn Application Security*. Wiley.